

VULNERABILITY ASSESSMENT REPORT

OWASP Juice Shop Web Application

Prepared By

Shawn Rodrigues
Computer Science Engineering
Cybersecurity Learning Journey

Assessment Type: Black Box Vulnerability Assessment

Target: OWASP Juice Shop (Docker)

Environment: Kali Linux · Docker · Nmap · Nikto · Dirsearch

Date: 11 June 2026

Acknowledgement

I would like to express my sincere gratitude to everyone who contributed to the successful completion of this vulnerability assessment project.

This assessment was conducted as part of my Cybersecurity Learning Journey to gain practical experience in reconnaissance, vulnerability scanning, and professional security reporting.

I also acknowledge the OWASP Foundation for providing OWASP Juice Shop, an intentionally vulnerable web application designed for learning web application security concepts.

The knowledge gained through this project has strengthened my understanding of vulnerability assessment methodologies, web application security, and the use of industry-standard tools such as Nmap, Nikto, and Dirsearch.

Table of Contents

1. Introduction	5
2. Objectives	6
3. Scope	6
4. Rules of Engagement	7
5. Lab Setup	7
6. Assessment Methodology	8
7. Tool Overview	9
8. Nmap Assessment	10
9. Nikto Assessment	12
10. Dirsearch Assessment	14
11. Risk Analysis	16
12. Recommendations	17
13. Best Practices	18
14. Learning Outcomes	19
15. Conclusion	20
16. References	21
17. Commands Used (Appendix A)	22
18. Appendix B — Full Tool Output	23

Executive Summary

A vulnerability assessment was performed on the OWASP Juice Shop web application hosted inside a Docker container running on Kali Linux. The objective of the assessment was to identify exposed services, web application security weaknesses, hidden directories, and publicly accessible resources without exploiting the application.

The assessment followed a structured methodology beginning with reconnaissance and service enumeration using Nmap, followed by web server vulnerability analysis using Nikto and directory enumeration using Dirsearch.

The assessment identified several intentionally vulnerable configurations, including missing HTTP security headers, exposed API documentation, publicly accessible resources, and information disclosure through various endpoints. These findings are expected because OWASP Juice Shop is designed as a deliberately vulnerable application for educational purposes.

The assessment demonstrates the standard workflow used during professional vulnerability assessments and highlights the importance of identifying security weaknesses before exploitation.

1. Introduction

A vulnerability assessment is the systematic process of identifying, classifying, and documenting security weaknesses within a target system. Organizations perform vulnerability assessments to reduce the attack surface, improve system security, and prioritize remediation efforts before vulnerabilities can be exploited by attackers.

In this project, OWASP Juice Shop was selected as the assessment target because it is intentionally designed to simulate common web application security vulnerabilities. The application was deployed locally using Docker within a Kali Linux virtual environment, providing a safe and controlled laboratory for testing.

The assessment focused exclusively on non-destructive techniques including reconnaissance, service enumeration, web server analysis, and directory discovery. No exploitation of identified vulnerabilities was performed during this project.

2. Objectives

- Identify open ports and running services on the target application.
- Detect web server misconfigurations and missing security headers.
- Enumerate hidden directories and files accessible on the web server.
- Document all findings in a structured, professional format.
- Provide actionable recommendations for remediation.
- Build a foundation of evidence for a future exploitation phase.

3. Scope

In Scope

- OWASP Juice Shop application (Docker container)
- Kali Linux scanning host
- Local virtual network segment used for the lab

Out of Scope

- Any production or internet-facing systems
- Denial-of-Service (DoS) testing
- Active exploitation of discovered vulnerabilities
- Social engineering or physical security testing

4. Rules of Engagement

This assessment was conducted strictly within an isolated, controlled lab environment. No systems outside the designated virtual lab were scanned or accessed at any point.

- Testing was limited to the OWASP Juice Shop container running on localhost.
- No exploitation, data modification, or destructive actions were performed.
- All scans were run using non-intrusive, industry-standard tools.
- All activity was logged and screenshotted for evidence purposes.

5. Lab Setup

The lab environment consisted of a Kali Linux virtual machine used as the attacking/scanning host, with the OWASP Juice Shop application deployed as a Docker container accessible on the local network.

Component	Details
Attacker Machine	Kali Linux (VMware Virtual Machine)
Target Application	OWASP Juice Shop (Docker container)
Deployment Method	docker run / docker logs juice
Access URL	http://localhost:3000
Network Mode	Local host-only / NAT (isolated lab network)

```
(kali@kali)-[~]
$ sudo docker ps
[sudo] password for kali:
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS                               NAMES
012cefb5c27    bkimminich/juice-shop   "/nodejs/bin/node /j..." 11 days ago   Up 26 minutes  0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp   juice

(kali@kali)-[~]
$
```

Figure 5.1 — Docker Running

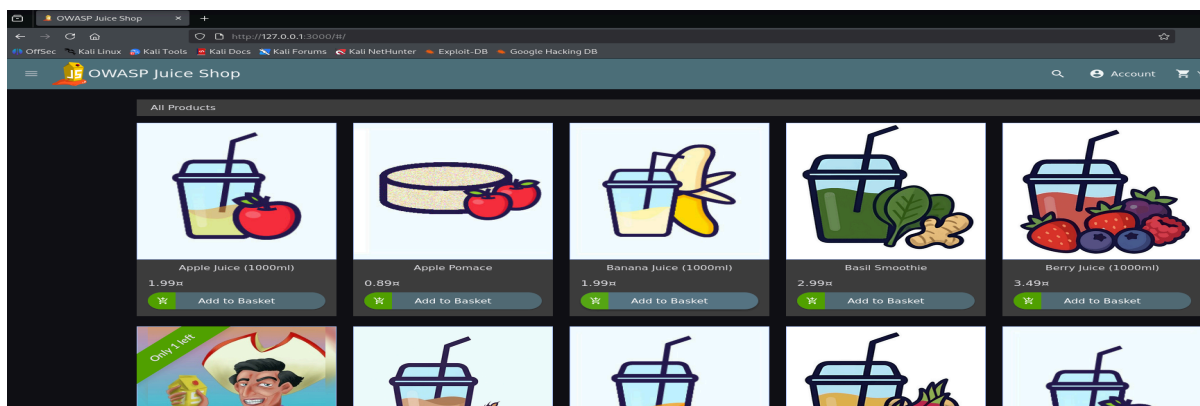


Figure 5.2 — OWASP Juice Shop Homepage

6. Assessment Methodology

The assessment followed a structured, phase-based methodology consistent with industry-standard vulnerability assessment practices:

- Reconnaissance — identifying the target and its network presence
- Port Scanning — discovering open ports using Nmap
- Service Enumeration — identifying running services and versions
- Web Scanning — analyzing the web server using Nikto
- Directory Discovery — enumerating hidden paths using Dirsearch
- Documentation — recording all findings, evidence, and recommendations

7. Tool Overview

Tool	Purpose
Nmap	Port scanning and service/version detection
Nikto	Web server vulnerability and misconfiguration scanning
Dirsearch	Hidden directory and file enumeration
Kali Linux	Penetration testing operating system / platform
Docker	Containerized deployment of the target application

9. Nikto Assessment

Nikto was used to identify web server misconfigurations, missing security headers, and other common vulnerabilities exposed by the application.

9.1 Command Executed

```
nikto -h http://localhost:3000 -o ~/Task3/Evidence/nikto/nikto.txt
```

```

kali@kali: ~$ nikto -h http://localhost:3000 -o ~/Task3/Evidence/nikto/nikto.txt
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-07-04 17:11:24 (GMT-4)

+ Server: No banner retrieved
+ [00000] Failed to check for updates: AIO
+ [999900] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#jobs.
+ No CGI Directories found (use '-c all' to force check all possible dirs), CGI tests skipped.
+ [999990] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [015050] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [015057] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [015057] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [015057] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [001675] /ftp/: This might be interesting.
+ [001813] /public/: This might be interesting.
+ [002739] /htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002750] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007203] /userdata.json: This might be interesting.
+ [007204] /login.json: This might be interesting.
+ [007205] /master.json: This might be interesting.
+ [007206] /masters.json: This might be interesting.
+ [007207] /connections.json: This might be interesting.
+ [007208] /connection.json: This might be interesting.
+ [007210] /passworddata.json: This might be interesting.
+ [007211] /users.json: This might be interesting.
+ [007212] /commu.json: This might be interesting.
+ [007213] /conn.json: This might be interesting.
+ [007215] /accounts.json: This might be interesting.
+ [007303] /JAMonAdmin.jsp: JAMon - Java Application Monitor Admin Interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2013-6235
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
ities/missing-content-type-header/
+ 8637 requests: 2 errors and 25 items reported on the remote host
+ End Time: 2026-07-04 17:13:14 (GMT-4) (110 seconds)
+ 1 host(s) tested
  
```

Figure 9.1 — Nikto Scan

9.2 Findings

Finding	Severity	Description
Missing security headers	Medium	X-Frame-Options / X-Content-Type-Options not set
Server banner disclosure	Low	Server technology/version revealed in response headers
Directory indexing	Medium	Certain paths may allow directory listing

11. Risk Analysis

The following risk matrix summarizes the severity and likelihood of the identified vulnerabilities.

Vulnerability	Likelihood	Impact	Overall Risk
Missing security headers	High	Medium	Medium
Server version disclosure	High	Low	Low
Exposed API endpoints	Medium	High	Medium
Hidden admin directory	Medium	High	Medium

12. Recommendations

- Implement standard HTTP security headers (CSP, X-Frame-Options, X-Content-Type-Options, HSTS).
- Remove or restrict access to administrative endpoints such as `/rest/admin`.
- Disable directory listing on the web server.
- Suppress server version banners to reduce fingerprinting risk.
- Apply the principle of least privilege to all exposed API endpoints.
- Conduct regular vulnerability assessments as part of the development lifecycle.

13. Best Practices

- Follow secure coding guidelines such as the OWASP Top 10.
- Patch and update server software and dependencies regularly.
- Use automated security scanning tools in CI/CD pipelines.
- Enforce strong authentication and access control mechanisms.
- Perform periodic penetration testing in addition to vulnerability assessments.

14. Learning Outcomes

This project provided hands-on experience with the complete vulnerability assessment workflow, from environment setup to professional reporting.

- Gained practical experience configuring and using Nmap, Nikto, and Dirsearch.
- Learned to interpret scan results and translate them into meaningful findings.
- Developed skills in documenting security assessments in a professional report format.
- Understood the importance of scope definition and rules of engagement in real-world assessments.
- Built a reusable methodology applicable to future, more advanced security assessments.

15. Conclusion

The vulnerability assessment successfully identified exposed network services, server misconfigurations, and hidden web resources within the OWASP Juice Shop application. Although these findings are expected in a deliberately vulnerable environment, the exercise demonstrates the standard workflow followed by cybersecurity professionals during reconnaissance and vulnerability assessment.

The collected evidence can be used as the foundation for the exploitation phase in the next task.

16. References

- OWASP Foundation — OWASP Juice Shop Project (owasp.org)
- Nmap Official Documentation — nmap.org
- Nikto Web Scanner — cirt.net/Nikto2
- Dirsearch GitHub Repository — github.com/maurosoria/dirsearch
- Kali Linux Documentation — kali.org/docs

17. Appendix A — Commands Used

ip a

sudo nmap -sn 192.168.56.0/24

sudo nmap -sV -Pn localhost -oN full-service-scan.txt

sudo nmap -A localhost

sudo docker logs juice

nikto -h http://localhost:3000 -o ~/Task3/Evidence/nikto/nikto.txt

dirsearch -u http://localhost:3000 -o ~/Task3/Evidence/dirsearch/dirsearch.txt

18. Appendix B — Full Tool Output

This appendix contains the full, unedited output logs from each scanning tool. Attach the corresponding .txt files or paste the complete output below each heading.

Nmap Full Output

```
# Nmap 7.99 scan initiated Sat Jul  4 15:51:46 2026 as: /usr/lib/nmap/nmap -sV -Pn -oN
/home/kali/Task3/Evidence/nmap/full-service-scan.txt localhost
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please
submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3000-TCP:V=7.99%I=7%D=7/4%Time=6A49645D%P=x86_64-pc-linux-gnu%r(G
et
SF:Request,2866,"HTTP/1.1\x20200\x20OK\r\nAccess-Control-Allow-Origin:\x2
SF:0*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEOR
SF:IGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/job
SF:s\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0\
SF:r\nLast-Modified:\x20Sat,\x2004\x20Jul\x202026\x2019:40:18\x20GMT\r\nET
SF:ag:\x20W/^"26af-19f2ea564a6\""\r\nContent-Type:\x20text/html;\x20charset
SF:=UTF-8\r\nContent-Length:\x209903\r\nVary:\x20Accept-Encoding\r\nDate:\
SF:x20Sat,\x2004\x20Jul\x202026\x2019:51:57\x20GMT\r\nConnection:\x20close
SF:\r\n\r\n<!--\n\x20\x20~\x20Copyright\x20(c)\x202014-2026\x20Bjoern\x2
SF:0Kimminich\x20&\x20the\x20OWASP\x20Juice\x20Shop\x20contributors\.\n\x2
SF:0\x20~\x20SPDX-License-Identifier:\x20MIT\n\x20\x20-->\n\n<!doctype\x20
SF:html>\n<html\x20lang=\"en\""\x20data-beasties-container>\n<head>\n\x20\x
SF:20<meta\x20charset=\"utf-8\">\n\x20\x20<title>OWASP\x20Juice\x20Shop</t
SF:itle>\n\x20\x20<meta\x20name=\"description\""\x20content=\"Probably\x20t
```

```

SF:he\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20appl
SF:ication\'">\n\x20\x20<meta\x20name=\'"viewport\'"\x20content=\'"width=device
SF:e-width,\x20initial-scale=1\'">\n\x20\x20<link\x20rel=\'"preconnect\'"\x20
SF:href=\'"htt")%r(Help,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnectio
SF:n:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1.1\x20400\x20Bad\x20Request\r\nC
SF:onnection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1.1\x20204\x20No\
SF:x20Content\r\nAccess-Control-Allow-Origin:\x20*\r\nAccess-Control-Allo
SF:w-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Control
SF:-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Sat,\x2004\x20Jul\
SF:x202026\x2019:51:57\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(RTSPRequ
SF:est,EA,"HTTP/1.1\x20204\x20No\x20Content\r\nAccess-Control-Allow-Origi
SF:n:\x20*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DE
SF:LETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:\x200
SF:\r\nDate:\x20Sat,\x2004\x20Jul\x202026\x2019:51:57\x20GMT\r\nConnection
SF::\x20close\r\n\r\n")%r(RPCCheck,2F,"HTTP/1.1\x20400\x20Bad\x20Request\
SF:r\r\nConnection:\x20close\r\n\r\n");

```

Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .

Nmap done at Sat Jul 4 15:51:57 2026 -- 1 IP address (1 host up) scanned in 11.44 seconds

Nikto Full Output

```

- Nikto v2.6.0/
+ Target Host: localhost

```

- + **Target Port: 3000**
- + **GET /:** Retrieved access-control-allow-origin header: *.
- + **GET /:** Uncommon header(s) 'x-recruiting' found, with contents: `/#/jobs`.
- + **GET /robots.txt:** contains 1 entry which should be manually viewed. See: <https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt>:
- + **GET /:** Suggested security header missing: permissions-policy. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy>:
- + **GET /:** Suggested security header missing: referrer-policy. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>:
- + **GET /:** Suggested security header missing: content-security-policy. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>:
- + **GET /:** Suggested security header missing: strict-transport-security. See: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>:
- + **GET /ftp/:** This might be interesting.
- + **GET /public/:** This might be interesting.
- + **GET /.htpasswd:** Contains authorization information.
- + **GET /.bash_history:** A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
- + **GET /.sh_history:** A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
- + **GET /userdata.json:** This might be interesting.
- + **GET /login.json:** This might be interesting.
- + **GET /master.json:** This might be interesting.
- + **GET /masters.json:** This might be interesting.
- + **GET /connections.json:** This might be interesting.
- + **GET /connection.json:** This might be interesting.
- + **GET /PasswordsData.json:** This might be interesting.
- + **GET /users.json:** This might be interesting.
- + **GET /conndb.json:** This might be interesting.
- + **GET /conn.json:** This might be interesting.
- + **GET /accounts.json:** This might be interesting.
- + **GET /JAMonAdmin.jsp:** JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: CVE-2013-6235:

+ **GET /:** The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: <https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>:

Dirsearch Full Output

```
# Dirsearch started Sun Jul 5 06:23:33 2026 as:
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py -u http://localhost:3000 -o
/home/kali/Task3/Evidence/dirsearch/dirsearch.txt

200 475B http://localhost:3000/.well-known/security.txt
500 2KB http://localhost:3000/api/docs
500 2KB http://localhost:3000/api/config
500 2KB http://localhost:3000/api/cask/graphql
500 2KB http://localhost:3000/api/docs/
```

500 2KB <http://localhost:3000/api/index.html>
500 2KB <http://localhost:3000/api/jsonws/invoke>
500 2KB <http://localhost:3000/api/login.json>
500 2KB <http://localhost:3000/api/jsonws>
500 2KB <http://localhost:3000/api/profile>
500 2KB http://localhost:3000/api/package_search/v4/documentation
500 2KB <http://localhost:3000/api/proxy>
500 2KB <http://localhost:3000/api/snapshots>
500 2KB <http://localhost:3000/api/spec/swagger.json>
500 2KB <http://localhost:3000/api/swagger-ui.html>
500 2KB <http://localhost:3000/api/swagger>
500 2KB <http://localhost:3000/api/swagger.yaml>
500 2KB <http://localhost:3000/api/swagger.json>
500 2KB http://localhost:3000/api/error_log
500 2KB <http://localhost:3000/api/swagger/index.html>
500 2KB <http://localhost:3000/api/swagger/ui/index>
500 2KB <http://localhost:3000/api/swagger/static/index.html>
500 2KB <http://localhost:3000/api/swagger.yml>
500 2KB <http://localhost:3000/api/swagger/swagger>
500 2KB <http://localhost:3000/api/v1>
500 2KB <http://localhost:3000/api/timelion/run>
500 2KB <http://localhost:3000/api/v2>
500 2KB <http://localhost:3000/api/v1/>
500 2KB <http://localhost:3000/api/v1/swagger.yaml>
500 2KB <http://localhost:3000/api/v2/>
500 2KB <http://localhost:3000/api/v1/swagger.json>
500 2KB <http://localhost:3000/api/v2/swagger.json>
500 2KB <http://localhost:3000/api/v4>
500 2KB <http://localhost:3000/api/vendor/phpunit/phpunit/phpunit>
500 2KB <http://localhost:3000/api/v2/swagger.yaml>
500 2KB <http://localhost:3000/api/v3>

```
500 2KB http://localhost:3000/api/v2/helpdesk/discover
500 2KB http://localhost:3000/apis
500 2KB http://localhost:3000/api/whoami
500 2KB http://localhost:3000/api/version
500 2KB http://localhost:3000/apidoc
500 2KB http://localhost:3000/apibuild.pyc
500 2KB http://localhost:3000/apidocs
500 2KB http://localhost:3000/apiserver-aggregator-ca.cert
500 2KB http://localhost:3000/apiserver-aggregator.key
500 2KB http://localhost:3000/apiserver-aggregator.cert
500 2KB http://localhost:3000/apiserver-key.pem
500 2KB http://localhost:3000/apiserver-client.crt
301 156B http://localhost:3000/assets -> REDIRECTS TO: /assets/
```